

Encuesta Integral INES-ENS para Organizaciones que Colaboran con el Sector Público

Versión 1.0 — Inspirada en ENS (RD 311/2022), INES y guías CCN-STIC 815 y 824.[web:8][web:20]
[web:33][web:37]

Objetivo: conocer, sin anestesia pero con cariño, el verdadero estado de la seguridad, la madurez y la resiliencia digital de su organización.

0. Información general de la organización

1. Nombre de la organización
2. Respuesta abierta.
3. Sector principal de actividad
4. Administración pública (AGE, autonómica, local).
5. Entidad del sector público institucional (organismo autónomo, entidad pública empresarial, etc.).
6. Proveedor tecnológico del sector público.
7. Operador de servicios esenciales / importantes (NIS2 / sector crítico).
8. Universidad o centro de I+D.
9. Otros (especificar).
10. Tamaño aproximado de la organización (empleados)
 11. Menos de 50.
 12. Entre 50 y 249.
 13. Entre 250 y 999.
 14. 1.000 o más.
15. Rol de la persona que responde
 16. CISO / Responsable de Seguridad de la Información (CISO/RSSI).
 17. CIO / Responsable de Sistemas y Tecnologías.
 18. Responsable de Cumplimiento / Riesgos / Auditoría.
 19. Dirección General / Gerencia / Alta Dirección.
 20. Otro (especificar).
21. Sistemas de información relevantes afectados por el ENS
 22. Ninguno (no aplicaría ENS formalmente, solo buenas prácticas).
 23. Uno o varios sistemas de categoría Básica.
 24. Uno o varios sistemas de categoría Media.
 25. Uno o varios sistemas de categoría Alta.

26. No lo sabemos con certeza (todavía).

Respuesta abierta.

Sector principal de actividad

Otros (especificar).

Tamaño aproximado de la organización (empleados)

1.000 o más.

Rol de la persona que responde

Otro (especificar).

Sistemas de información relevantes afectados por el ENS

1. Gobierno y estrategia de seguridad (marco ENS)

27. ¿Existe una política de seguridad de la información formalmente aprobada por la alta dirección, alineada con el ENS?
28. Sí, formalmente aprobada, revisada en los últimos 12 meses.
29. Sí, pero la última revisión es de hace más de 12 meses.
30. Existe un borrador en circulación, pero no está formalmente aprobada.
31. No existe, aunque se aplican prácticas dispersas.
32.
No existe ni se espera a corto plazo.
33.
La política de seguridad de la información...
34. Abarca explícitamente los sistemas afectos al ENS y lo menciona.[web:8][web:37]
35. Abarca la mayor parte de los sistemas, pero no menciona ENS de forma explícita.
36. Se centra solo en TI corporativas, sin referencia a sistemas ENS.
37.
Desconocido.
38.
¿Dispone la organización de una estrategia o plan director de ciberseguridad a 2–3 años?
39. Sí, formalmente aprobado, con presupuesto asociado.
40. Sí, pero sin presupuesto claramente vinculado.
41. Existe un plan de acción ENS “de supervivencia”, anual.
42. No, se actúa de forma reactiva por proyectos.
43.
No y no está previsto.
44.
¿Con qué frecuencia se informa formalmente a la alta dirección sobre el estado de la seguridad (incluido ENS/INES)?
45. Mensualmente.
46. Trimestralmente.
47. Anualmente (por ejemplo, con motivo del Informe de Estado de Seguridad).
48. Solo cuando ocurre algo “gordo”.
49.
Nunca o casi nunca.

50.

Grado de integración de ENS e INES en la gobernanza de la organización

ENS e INES son parte explícita del cuadro de mando corporativo.

ENS se tiene en cuenta para proyectos TIC, INES se cumple como trámite.

ENS se menciona en documentos, pero apenas influye en decisiones.

ENS/INES se perciben como un ejercicio administrativo externo.

ENS/INES son prácticamente desconocidos fuera del área de seguridad.

No existe ni se espera a corto plazo.

La política de seguridad de la información...

Desconocido.

¿Dispone la organización de una estrategia o plan director de ciberseguridad a 2-3 años?

No y no está previsto.

¿Con qué frecuencia se informa formalmente a la alta dirección sobre el estado de la seguridad (incluido ENS/INES)?

Nunca o casi nunca.

Grado de integración de ENS e INES en la gobernanza de la organización

- ENS e INES son parte explícita del cuadro de mando corporativo.
- ENS se tiene en cuenta para proyectos TIC, INES se cumple como trámite.
- ENS se menciona en documentos, pero apenas influye en decisiones.
- ENS/INES se perciben como un ejercicio administrativo externo.
- ENS/INES son prácticamente desconocidos fuera del área de seguridad.

2. Alcance ENS, perfiles de cumplimiento y certificación

51.

¿Ha definido la organización formalmente el alcance de aplicación del ENS (servicios, sistemas, datos, unidades)?

Sí, con un documento aprobado y mantenido.

Sí, pero informalmente (listados internos, sin aprobación formal).

Parcialmente (solo para algunos sistemas críticos).

No, el alcance se interpreta caso por caso.

No se ha considerado.

52.

Categoría predominante de los sistemas bajo ENS

Mayoría categoría Básica.

Mezcla de Básica y Media.

Predominio de Media.

Presencia significativa de Alta.

No se ha clasificado todavía.

53.

¿Se han empleado perfiles de cumplimiento específicos aprobados por el CCN (art. 37 RD 311/2022)?
[web:37][web:40]

Sí, perfiles sectoriales o colectivos específicos.

Sí, perfiles internos alineados con los perfiles CCN.

No, pero estamos evaluándolo.

No, aplicamos las medidas ENS “en bruto”.

Desconocido.

54.

Estado de certificación / aprobación de conformidad con el ENS

Certificación formal de conformidad en algún sistema.

Declaración de conformidad aprobada sin certificación externa.

Evaluación interna periódica, sin declarar formalmente la conformidad.

No se ha iniciado ningún proceso formal.

Desconocido.

55.

Uso de INES para sustentar la conformidad

Sí, se usa INES como fuente principal de evidencias para ENS.

Se usa parcialmente, combinado con otras herramientas y hojas de cálculo.

Se envía INES, pero la conformidad se gestiona al margen.

No se considera INES como elemento relevante para conformidad ENS.

No aplicable.

¿Ha definido la organización formalmente el alcance de aplicación del ENS (servicios, sistemas, datos, unidades)?

- Sí, con un documento aprobado y mantenido.
- Sí, pero informalmente (listados internos, sin aprobación formal).
- Parcialmente (solo para algunos sistemas críticos).
- No, el alcance se interpreta caso por caso.
- No se ha considerado.

Categoría predominante de los sistemas bajo ENS

- Mayoría categoría Básica.
- Mezcla de Básica y Media.
- Predominio de Media.
- Presencia significativa de Alta.
- No se ha clasificado todavía.

¿Se han empleado perfiles de cumplimiento específicos aprobados por el CCN (art. 37 RD 311/2022)?
[web:37][web:40]

- Sí, perfiles sectoriales o colectivos específicos.
- Sí, perfiles internos alineados con los perfiles CCN.
- No, pero estamos evaluándolo.
- No, aplicamos las medidas ENS “en bruto”.
- Desconocido.

Estado de certificación / aprobación de conformidad con el ENS

- Certificación formal de conformidad en algún sistema.
- Declaración de conformidad aprobada sin certificación externa.
- Evaluación interna periódica, sin declarar formalmente la conformidad.
- No se ha iniciado ningún proceso formal.
- Desconocido.

Uso de INES para sustentar la conformidad

- Sí, se usa INES como fuente principal de evidencias para ENS.
- Se usa parcialmente, combinado con otras herramientas y hojas de cálculo.
- Se envía INES, pero la conformidad se gestiona al margen.
- No se considera INES como elemento relevante para conformidad ENS.
- No aplicable.

3. Métricas de implantación de medidas ENS (CCN-STIC 815 y 824)

56.

Estado global de implantación de medidas ENS en sistemas bajo alcance

Más del 90 % de las medidas ENS aplicables están implantadas.

Entre el 70 % y el 90 %.

Entre el 50 % y el 70 %.

Menos del 50 %.

No disponemos de una estimación fiable.

57.

Para las medidas ENS implantadas, ¿la organización dispone de evidencias documentadas y actualizadas (procedimientos, registros, configuraciones)?

Sí, para la inmensa mayoría de las medidas.

Sí, para la mayoría, con algunas lagunas.

Solo para medidas críticas y auditorías recientes.

Escasamente; gran parte del conocimiento es tácito u oral.

No se dispone de evidencias estructuradas.

58.

¿Con qué frecuencia se revisa el grado de implantación de las medidas ENS?

Al menos una vez al año, mediante un proceso formal.

Cada 2–3 años o coincidiendo con auditorías externas.

Solo cuando se añaden nuevos sistemas o proyectos.

De forma esporádica y no sistemática.

No se revisa.

59.

Nivel de automatización para recopilar información sobre la implantación de medidas

Alto: herramientas GRC, inventarios CMDB, soluciones CCN integradas.

Medio: algunas herramientas, mucho Excel.

Bajo: recogida manual de datos, entrevistas, correos.

Nulo: la información se reconstruye ad hoc.

Desconocido.

60.

¿Se emplean las guías CCN-STIC específicas (806, 808, 809, 815, 824, etc.) como referencia explícita en la evaluación interna?[web:18][web:36][web:38][web:39]

Sí, forman parte de los procedimientos oficiales.

Sí, como guía práctica, pero no formalizada.

Solo se consultan puntualmente.

No se utilizan.

Desconocido.

Estado global de implantación de medidas ENS en sistemas bajo alcance

- Más del 90 % de las medidas ENS aplicables están implantadas.
- Entre el 70 % y el 90 %.
- Entre el 50 % y el 70 %.
- Menos del 50 %.
- No disponemos de una estimación fiable.

Para las medidas ENS implantadas, ¿la organización dispone de evidencias documentadas y actualizadas (procedimientos, registros, configuraciones)?

- Sí, para la inmensa mayoría de las medidas.
- Sí, para la mayoría, con algunas lagunas.
- Solo para medidas críticas y auditorías recientes.
- Escasamente; gran parte del conocimiento es tácito u oral.
- No se dispone de evidencias estructuradas.

¿Con qué frecuencia se revisa el grado de implantación de las medidas ENS?

- Al menos una vez al año, mediante un proceso formal.
- Cada 2–3 años o coincidiendo con auditorías externas.
- Solo cuando se añaden nuevos sistemas o proyectos.
- De forma esporádica y no sistemática.
- No se revisa.

Nivel de automatización para recopilar información sobre la implantación de medidas

- Alto: herramientas GRC, inventarios CMDB, soluciones CCN integradas.
- Medio: algunas herramientas, mucho Excel.
- Bajo: recogida manual de datos, entrevistas, correos.
- Nulo: la información se reconstruye ad hoc.
- Desconocido.

¿Se emplean las guías CCN-STIC específicas (806, 808, 809, 815, 824, etc.) como referencia explícita en la evaluación interna?[web:18][web:36][web:38][web:39]

- Sí, forman parte de los procedimientos oficiales.
- Sí, como guía práctica, pero no formalizada.
- Solo se consultan puntualmente.
- No se utilizan.
- Desconocido.

4. Métricas de eficacia y eficiencia (según CCN-STIC 815, 817, 824)

61.

¿Dispone la organización de indicadores de eficacia de las medidas de seguridad (por ejemplo, reducción de incidentes, disminución de vulnerabilidades críticas)?

Sí, definidos y reportados regularmente.

Sí, pero de forma parcial o ad hoc.

Algunos datos se revisan, sin tratarse como indicadores.

No disponemos de indicadores de eficacia.

Desconocido.

62.

¿Dispone de indicadores de eficiencia (esfuerzo humano, coste, tiempos) asociados a la seguridad?
[web:30][web:33]

Sí, se monitorizan horas dedicadas, costes y servicios externalizados.

Solo algunos costes, sin relacionarlos claramente con resultados.

Puntualmente, para justificación de proyectos.

No se mide la eficiencia de la seguridad.

Desconocido.

63.

¿Se calculan métricas sobre el tiempo medio de detección (MTTD), respuesta (MTTR) y recuperación de incidentes relevantes?

Sí, para todos los incidentes significativos.

Sí, pero solo para incidentes críticos o graves.

Se calculan, pero de forma inconsistente.

No se calculan.

No aplicable.

64.

En la práctica, ¿cómo se utilizan los indicadores de eficacia y eficiencia?

Para priorizar medidas y proyectos de seguridad.

Para justificar presupuestos a la dirección.

Principalmente para cumplir obligaciones de reporte (INES, ENS).

No se utilizan de manera sistemática.

Desconocido.

65.

¿Se vinculan los indicadores de seguridad con indicadores de continuidad de negocio y resiliencia (por ejemplo, RTO, RPO, disponibilidad real)?

Sí, existe un cuadro de mando conjunto.

Sí, pero solo en determinados servicios críticos.

Existe continuidad de negocio, pero poco conectada con ciberseguridad.

No se ha realizado este vínculo.

Desconocido.

¿Dispone la organización de indicadores de eficacia de las medidas de seguridad (por ejemplo, reducción de incidentes, disminución de vulnerabilidades críticas)?

- Sí, definidos y reportados regularmente.
- Sí, pero de forma parcial o ad hoc.
- Algunos datos se revisan, sin tratarse como indicadores.
- No disponemos de indicadores de eficacia.
- Desconocido.

¿Dispone de indicadores de eficiencia (esfuerzo humano, coste, tiempos) asociados a la seguridad?

[web:30][web:33]

- Sí, se monitorizan horas dedicadas, costes y servicios externalizados.
- Solo algunos costes, sin relacionarlos claramente con resultados.
- Puntualmente, para justificación de proyectos.
- No se mide la eficiencia de la seguridad.
- Desconocido.

¿Se calculan métricas sobre el tiempo medio de detección (MTTD), respuesta (MTTR) y recuperación de incidentes relevantes?

- Sí, para todos los incidentes significativos.
- Sí, pero solo para incidentes críticos o graves.
- Se calculan, pero de forma inconsistente.
- No se calculan.
- No aplicable.

En la práctica, ¿cómo se utilizan los indicadores de eficacia y eficiencia?

- Para priorizar medidas y proyectos de seguridad.
- Para justificar presupuestos a la dirección.
- Principalmente para cumplir obligaciones de reporte (INES, ENS).
- No se utilizan de manera sistemática.
- Desconocido.

¿Se vinculan los indicadores de seguridad con indicadores de continuidad de negocio y resiliencia (por ejemplo, RTO, RPO, disponibilidad real)?

- Sí, existe un cuadro de mando conjunto.
- Sí, pero solo en determinados servicios críticos.
- Existe continuidad de negocio, pero poco conectada con ciberseguridad.
- No se ha realizado este vínculo.
- Desconocido.

5. Gestión de ciberincidentes y uso de métricas (CCN-STIC 817)

66.

¿Dispone la organización de un procedimiento formal de gestión de ciberincidentes alineado con la guía CCN-STIC 817 o equivalente? [web:30][web:32]

Sí, formalizado, conocido y probado.

Sí, formalizado pero poco ejercitado.

Existe un procedimiento oficioso o heredado.

No existe un procedimiento claro.

No se conoce.

67.

¿Cómo se registran los ciberincidentes?

Herramienta específica (LUCÍA, SIEM/SOC, herramienta GRC, etc.).

Sistema de tickets corporativo.

Hojas de cálculo u otras soluciones manuales.

Principalmente vía correo electrónico / teléfono.

No se registran de forma sistemática.

68.

Métricas empleadas sobre ciberincidentes (marque todas las que apliquen)

Número de incidentes por tipología (malware, phishing, denegación de servicio, etc.).

Número de incidentes por criticidad (leve, moderado, grave, muy grave).

Tiempo medio de detección y respuesta.

Impacto sobre servicios críticos (indisponibilidades, datos afectados).

Reincidencia de causas raíz.

No se emplean métricas específicas.

69.

Frecuencia de análisis de tendencias de ciberincidentes

Mensual.

Trimestral.

Anual.

Solo tras incidentes especialmente graves.

No se realiza análisis de tendencias.

70.

¿Se comparten indicadores o resultados de ciberincidentes con el CCN-CERT u otras autoridades competentes (en el marco ENS, NIS2 u otros)?

Sí, de forma sistemática.

Sí, pero solo para ciertos incidentes.

Puntualmente, sin proceso claro.

No.

Desconocido.

¿Dispone la organización de un procedimiento formal de gestión de ciberincidentes alineado con la guía CCN-STIC 817 o equivalente? [web:30][web:32]

- Sí, formalizado, conocido y probado.
- Sí, formalizado pero poco ejercitado.
- Existe un procedimiento oficioso o heredado.
- No existe un procedimiento claro.
- No se conoce.

¿Cómo se registran los ciberincidentes?

- Herramienta específica (LUCÍA, SIEM/SOC, herramienta GRC, etc.).
- Sistema de tickets corporativo.
- Hojas de cálculo u otras soluciones manuales.
- Principalmente vía correo electrónico / teléfono.
- No se registran de forma sistemática.

Métricas empleadas sobre ciberincidentes (marque todas las que apliquen)

- Número de incidentes por tipología (malware, phishing, denegación de servicio, etc.).
- Número de incidentes por criticidad (leve, moderado, grave, muy grave).
- Tiempo medio de detección y respuesta.
- Impacto sobre servicios críticos (indisponibilidades, datos afectados).
- Reincidencia de causas raíz.
- No se emplean métricas específicas.

Frecuencia de análisis de tendencias de ciberincidentes

- Mensual.
- Trimestral.
- Anual.
- Solo tras incidentes especialmente graves.
- No se realiza análisis de tendencias.

¿Se comparten indicadores o resultados de ciberincidentes con el CCN-CERT u otras autoridades competentes (en el marco ENS, NIS2 u otros)?

- Sí, de forma sistemática.
- Sí, pero solo para ciertos incidentes.
- Puntualmente, sin proceso claro.
- No.
- Desconocido.

6. Interconexiones, cadena de suministro y proveedores (ENS, NIS2)

71.

¿Se mantiene un inventario de interconexiones con otras entidades y proveedores, clasificadas por criticidad?

Sí, completo y actualizado.

Sí, pero con lagunas importantes.

Parcial (solo las interconexiones más evidentes).

No, se conoce solo de forma informal.

Desconocido.

72.

¿Se evalúa el cumplimiento ENS de los proveedores que prestan servicios al sector público en su nombre (subcontratas, cloud, SaaS, etc.)? [web:35]

Sí, con criterios y evidencias alineadas con ENS.

Sí, pero principalmente basados en ISO 27001, SOC 2 u otros.

Solo en licitaciones, sin seguimiento posterior.

No se evalúa de manera estructurada.

Desconocido.

73.

¿Existen cláusulas contractuales de seguridad alineadas con ENS y NIS2 (reporting de incidentes, niveles de servicio, auditoría)? [web:21][web:24][web:27][web:35]

Sí, en la mayoría de los contratos relevantes.

Sí, pero solo en los contratos más recientes.

Solo aparecen cláusulas genéricas.

No se incluyen cláusulas específicas.

Desconocido.

74.

¿Se monitoriza de forma periódica el desempeño de seguridad de los proveedores críticos?

Sí, con indicadores definidos y revisiones periódicas.

Sí, pero de forma informal, sin indicadores claros.

Solo cuando surge un incidente o problema.

No se monitoriza.

No aplicable.

75.

¿Se contemplan los proveedores críticos en los ejercicios de continuidad de negocio y ciber crisis?

Sí, se incluyen en simulacros y escenarios.

Solo en algunos ejercicios puntuales.

Se les informa, pero no se les integra en simulaciones.

No se les considera en ejercicios de ciber crisis.

No aplicable.

¿Se mantiene un inventario de interconexiones con otras entidades y proveedores, clasificadas por criticidad?

- Sí, completo y actualizado.
- Sí, pero con lagunas importantes.
- Parcial (solo las interconexiones más evidentes).
- No, se conoce solo de forma informal.
- Desconocido.

¿Se evalúa el cumplimiento ENS de los proveedores que prestan servicios al sector público en su nombre (subcontratas, cloud, SaaS, etc.)?[web:35]

- Sí, con criterios y evidencias alineadas con ENS.
- Sí, pero principalmente basados en ISO 27001, SOC 2 u otros.
- Solo en licitaciones, sin seguimiento posterior.
- No se evalúa de manera estructurada.
- Desconocido.

¿Existen cláusulas contractuales de seguridad alineadas con ENS y NIS2 (reporting de incidentes, niveles de servicio, auditoría)?[web:21][web:24][web:27][web:35]

- Sí, en la mayoría de los contratos relevantes.
- Sí, pero solo en los contratos más recientes.
- Solo aparecen cláusulas genéricas.
- No se incluyen cláusulas específicas.
- Desconocido.

¿Se monitoriza de forma periódica el desempeño de seguridad de los proveedores críticos?

- Sí, con indicadores definidos y revisiones periódicas.
- Sí, pero de forma informal, sin indicadores claros.
- Solo cuando surge un incidente o problema.
- No se monitoriza.
- No aplicable.

¿Se contemplan los proveedores críticos en los ejercicios de continuidad de negocio y ciber crisis?

- Sí, se incluyen en simulacros y escenarios.
- Solo en algunos ejercicios puntuales.
- Se les informa, pero no se les integra en simulaciones.
- No se les considera en ejercicios de ciber crisis.
- No aplicable.

7. Madurez de gestión de la seguridad (modelo tipo CMM)

Para las siguientes preguntas, utilice una escala de 1 a 5:

1 = Inicial / ad hoc, 2 = Repetible, 3 = Definido, 4 = Gestionado y medido, 5 = Optimizado.

76.

Nivel de madurez en gestión de riesgos de seguridad de la información

1, 2, 3, 4, 5 (seleccionar uno).

77.

Nivel de madurez en gestión de identidades y accesos

1, 2, 3, 4, 5.

78.

Nivel de madurez en gestión de ciberincidentes

1, 2, 3, 4, 5.

79.

Nivel de madurez en continuidad de negocio y recuperación ante desastres

1, 2, 3, 4, 5.

80.

Nivel de madurez en gestión de proveedores y cadena de suministro

1, 2, 3, 4, 5.

81.

Nivel de madurez en formación, concienciación y cultura de seguridad

1, 2, 3, 4, 5.

82.

Nivel de madurez en medición, indicadores y cuadros de mando de seguridad

1, 2, 3, 4, 5.

Nivel de madurez en gestión de riesgos de seguridad de la información

- 1, 2, 3, 4, 5 (seleccionar uno).

Nivel de madurez en gestión de identidades y accesos

- 1, 2, 3, 4, 5.

Nivel de madurez en gestión de ciberincidentes

- 1, 2, 3, 4, 5.

Nivel de madurez en continuidad de negocio y recuperación ante desastres

- 1, 2, 3, 4, 5.

Nivel de madurez en gestión de proveedores y cadena de suministro

- 1, 2, 3, 4, 5.

Nivel de madurez en formación, concienciación y cultura de seguridad

- 1, 2, 3, 4, 5.

Nivel de madurez en medición, indicadores y cuadros de mando de seguridad

- 1, 2, 3, 4, 5.

8. Uso de INES y herramientas de soporte (PILAR, LUCÍA, etc.)

83.

¿Utiliza la organización la plataforma INES para el envío del Informe de Estado de Seguridad?

Sí, directamente.

Sí, a través de una entidad intermedia.

No, aún no.

Desconocido.

84.

¿Cómo se organiza internamente la recopilación de datos para INES? [web:8][web:33]

Proceso formal consolidado, con responsables y plazos.

Coordinación informal entre áreas.

Recopilación “de emergencia” cuando llega la fecha límite.

No se ha definido todavía.

85.

¿Se reutilizan los datos de INES para la gestión interna (priorización, presupuesto, seguimiento de objetivos)?

Sí, se integran en el cuadro de mando de seguridad.

Sí, pero de forma indirecta o parcial.

No, se responde a INES y luego se archiva.

No aplica.

86.

Herramientas complementarias empleadas

PILAR para análisis y gestión de riesgos.

LUCÍA u otra herramienta específica para ciberincidentes.

Herramienta GRC corporativa.

Otras (especificar).

Ninguna específica, soluciones ad hoc.

87.

Nivel de satisfacción con la utilidad práctica de INES para la organización

Muy alto: aporta valor claro para la toma de decisiones.

Alto: útil, aunque mejorable.

Medio: se percibe principalmente como obligación administrativa.

Bajo: consume recursos, aporta poco valor percibido.

Muy bajo o nulo.

¿Utiliza la organización la plataforma INES para el envío del Informe de Estado de Seguridad?

- Sí, directamente.
- Sí, a través de una entidad intermedia.
- No, aún no.
- Desconocido.

¿Cómo se organiza internamente la recopilación de datos para INES?[web:8][web:33]

- Proceso formal consolidado, con responsables y plazos.
- Coordinación informal entre áreas.
- Recopilación “de emergencia” cuando llega la fecha límite.
- No se ha definido todavía.

¿Se reutilizan los datos de INES para la gestión interna (priorización, presupuesto, seguimiento de objetivos)?

- Sí, se integran en el cuadro de mando de seguridad.
- Sí, pero de forma indirecta o parcial.
- No, se responde a INES y luego se archiva.
- No aplica.

Herramientas complementarias empleadas

- PILAR para análisis y gestión de riesgos.
- LUCÍA u otra herramienta específica para ciberincidentes.
- Herramienta GRC corporativa.
- Otras (especificar).
- Ninguna específica, soluciones ad hoc.

Nivel de satisfacción con la utilidad práctica de INES para la organización

- Muy alto: aporta valor claro para la toma de decisiones.
- Alto: útil, aunque mejorable.
- Medio: se percibe principalmente como obligación administrativa.
- Bajo: consume recursos, aporta poco valor percibido.
- Muy bajo o nulo.

9. Inversión, esfuerzo y retorno percibido (IGM, ROI)

88.

Aproximadamente, ¿qué porcentaje del presupuesto TIC se dedica a seguridad de la información?

Menos del 3 %.

Entre el 3 % y el 6 %.

Entre el 6 % y el 10 %.

Más del 10 %.

Desconocido.

89.

¿Cuántas personas (equivalentes a jornada completa) se dedican principalmente a ciberseguridad?

Menos de 1.

Entre 1 y 3.

Entre 4 y 10.

Más de 10.

Desconocido.

90.

¿Se cuantifican de alguna forma las pérdidas evitadas o los incidentes evitados gracias a las medidas de seguridad (aunque sea de forma aproximada)?

Sí, con modelos cuantitativos o actuariales.

Sí, con estimaciones razonadas.

Solo en casos muy significativos.

No se realiza este ejercicio.

Desconocido.

91.

En términos de percepción, la organización considera que el retorno de inversión (ROI) en seguridad...

Es claramente positivo y visible.

Es razonable, aunque difícil de demostrar.

Es dudoso, se percibe como “coste obligado”.

Es desconocido.

Preferimos no responder.

92.

Nivel de apetito o tolerancia al riesgo en materia de ciberseguridad

Muy bajo: preferimos prevención intensa aunque suponga coste alto.

Bajo: priorizamos alta seguridad con cierta flexibilidad.

Moderado: equilibrio entre riesgo y coste.

Alto: aceptamos riesgos considerables por coste o agilidad.

No definido.

Aproximadamente, ¿qué porcentaje del presupuesto TIC se dedica a seguridad de la información?

- Menos del 3 %.
- Entre el 3 % y el 6 %.
- Entre el 6 % y el 10 %.
- Más del 10 %.
- Desconocido.

¿Cuántas personas (equivalentes a jornada completa) se dedican principalmente a ciberseguridad?

- Menos de 1.
- Entre 1 y 3.
- Entre 4 y 10.
- Más de 10.
- Desconocido.

¿Se cuantifican de alguna forma las pérdidas evitadas o los incidentes evitados gracias a las medidas de seguridad (aunque sea de forma aproximada)?

- Sí, con modelos cuantitativos o actuariales.
- Sí, con estimaciones razonadas.
- Solo en casos muy significativos.
- No se realiza este ejercicio.
- Desconocido.

En términos de percepción, la organización considera que el retorno de inversión (ROI) en seguridad...

- Es claramente positivo y visible.
- Es razonable, aunque difícil de demostrar.
- Es dudoso, se percibe como “coste obligado”.
- Es desconocido.
- Preferimos no responder.

Nivel de apetito o tolerancia al riesgo en materia de ciberseguridad

- Muy bajo: preferimos prevención intensa aunque suponga coste alto.
- Bajo: priorizamos alta seguridad con cierta flexibilidad.
- Moderado: equilibrio entre riesgo y coste.
- Alto: aceptamos riesgos considerables por coste o agilidad.
- No definido.

10. Visión de futuro: resiliencia, IA, post-cuántico

93.

¿Se ha evaluado el impacto de la computación cuántica en la criptografía que emplean sus sistemas críticos?

Sí, con un análisis formal de riesgos.

Sí, a nivel exploratorio.

No, pero está planificado.

No se ha considerado.

Desconocido.

94.

¿Se han identificado planes de migración hacia criptografía post-cuántica?

Sí, con hoja de ruta definida.

Sí, a nivel de estudio preliminar.

No, pero hay interés.

No se considera prioritario.

Desconocido.

95.

¿Emplea la organización sistemas de inteligencia artificial / aprendizaje automático para operaciones, negocio o seguridad?

Sí, ampliamente, incluyendo seguridad (detección, respuesta, etc.).

Sí, en algunas áreas, con gobernanza formal.

Sí, de forma experimental o piloto.

No se utilizan.

Desconocido.

96.

En caso afirmativo, ¿existen indicadores específicos sobre los riesgos asociados a IA (datos, modelos, decisiones automatizadas)?

Sí, se monitorizan métricas de riesgo y calidad.

Parcialmente, con ciertas métricas técnicas.

Se confía en el proveedor sin métricas propias.

No hay indicadores específicos.

No aplicable.

97.

¿Se han realizado ejercicios de ciber crisis que incluyan escenarios avanzados (ataque a cadena de suministro, ransomware masivo, fallo prolongado de nube)? [web:36]

Sí, en los últimos 12 meses.

Sí, pero hace más de un año.

Previsto para el próximo año.

No se han realizado.

Desconocido.

¿Se ha evaluado el impacto de la computación cuántica en la criptografía que emplean sus sistemas críticos?

- Sí, con un análisis formal de riesgos.
- Sí, a nivel exploratorio.
- No, pero está planificado.
- No se ha considerado.
- Desconocido.

¿Se han identificado planes de migración hacia criptografía post-cuántica?

- Sí, con hoja de ruta definida.
- Sí, a nivel de estudio preliminar.
- No, pero hay interés.
- No se considera prioritario.
- Desconocido.

¿Emplea la organización sistemas de inteligencia artificial / aprendizaje automático para operaciones, negocio o seguridad?

- Sí, ampliamente, incluyendo seguridad (detección, respuesta, etc.).
- Sí, en algunas áreas, con gobernanza formal.
- Sí, de forma experimental o piloto.
- No se utilizan.
- Desconocido.

En caso afirmativo, ¿existen indicadores específicos sobre los riesgos asociados a IA (datos, modelos, decisiones automatizadas)?

- Sí, se monitorizan métricas de riesgo y calidad.
- Parcialmente, con ciertas métricas técnicas.
- Se confía en el proveedor sin métricas propias.
- No hay indicadores específicos.
- No aplicable.

¿Se han realizado ejercicios de ciber crisis que incluyan escenarios avanzados (ataque a cadena de suministro, ransomware masivo, fallo prolongado de nube)?[web:36]

- Sí, en los últimos 12 meses.
- Sí, pero hace más de un año.
- Previsto para el próximo año.
- No se han realizado.
- Desconocido.

11. Preguntas abiertas (para espíritus inquietos)

98.

En una frase, ¿cuál considera que es la principal fortaleza de su organización en ciberseguridad?

Respuesta abierta.

99.

En una frase, ¿cuál es la principal debilidad o preocupación en materia de seguridad y resiliencia digital?

Respuesta abierta.

100.

Si pudiera cambiar una sola cosa en el enfoque ENS–INES para que fuera más útil a su organización, ¿qué propondría?

Respuesta abierta.

En una frase, ¿cuál considera que es la principal fortaleza de su organización en ciberseguridad?

- Respuesta abierta.

En una frase, ¿cuál es la principal debilidad o preocupación en materia de seguridad y resiliencia digital?

- Respuesta abierta.

Si pudiera cambiar una sola cosa en el enfoque ENS–INES para que fuera más útil a su organización, ¿qué propondría?

- Respuesta abierta.

Fin de la encuesta. Gracias por participar en este sofisticado ejercicio de introspección cibersegura.